Lab 2: Website Enumeration and Information Gathering

Tools Used

- Kali Linux
- Whatweb

Exercise 1:

Run the whatweb command to detect technologies for the following targets:

- example.com
- stackoverflow.com
- github.com

Command Used:whatweb example.com,whatweb stackflow.com,whatweb github.com



Record of Findings:

1. example.com:HTML5 and Cloudflare
2. stackoverflow.com: HTML5,Cloudflare,Script
3. github.com: HTML5,JavaScript, JSON,Open Graph Protocol, OpenSearch

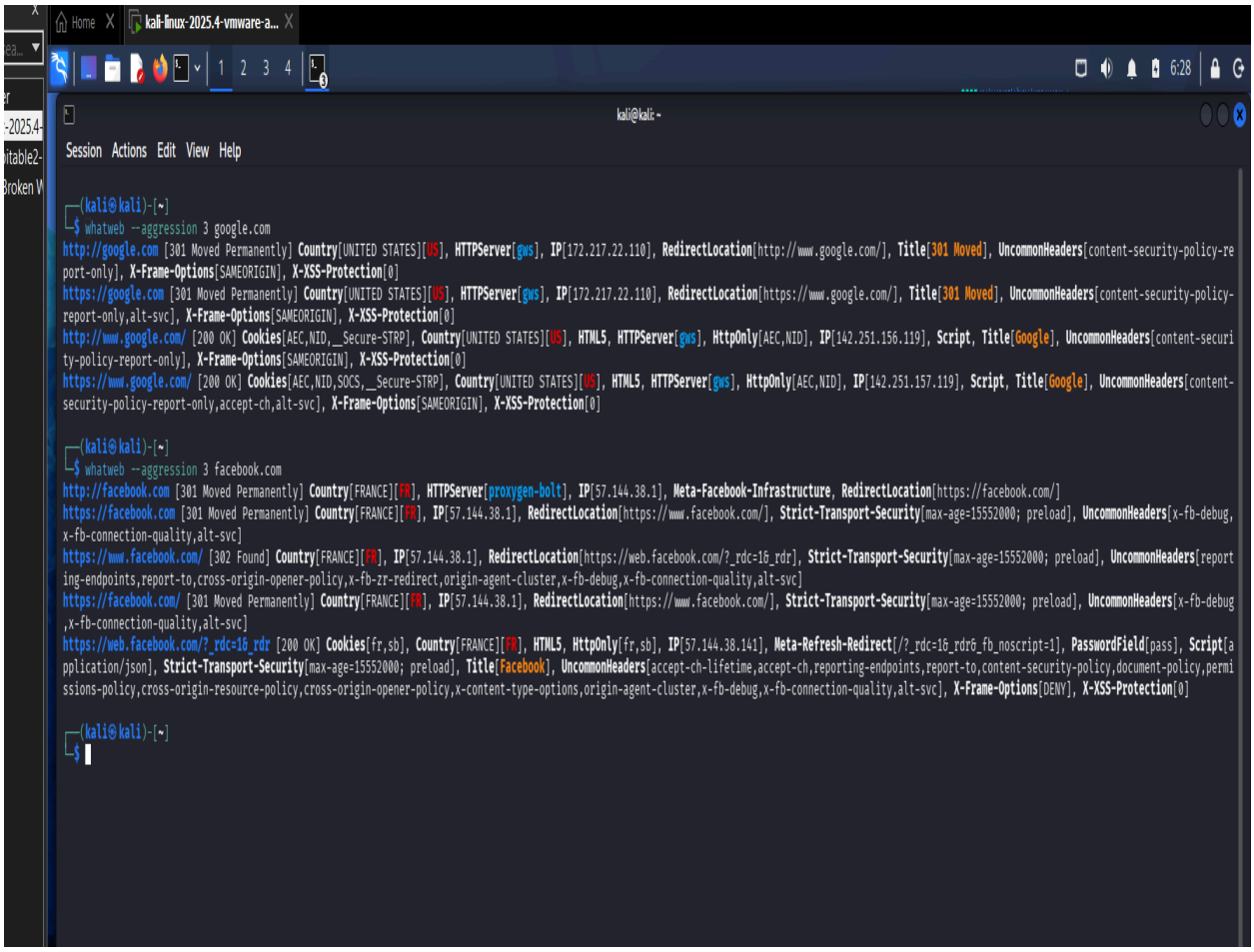
---

Exercise 2:

Perform an aggressive scan on the following targets:

- google.com
- facebook.com

Commands Used:whatweb --aggression 3 google.com,whatweb --aggression 3 facebook.com.



Findings:

1. google.com: HTML5 and Script

2. facebook.com: HTML5,Script, JSON,Meta-Facebook-Infrastructure, Meta-Refresh-Redirect

Lab 3: Subdomain Hunting

Tools Used

- Kali Linux

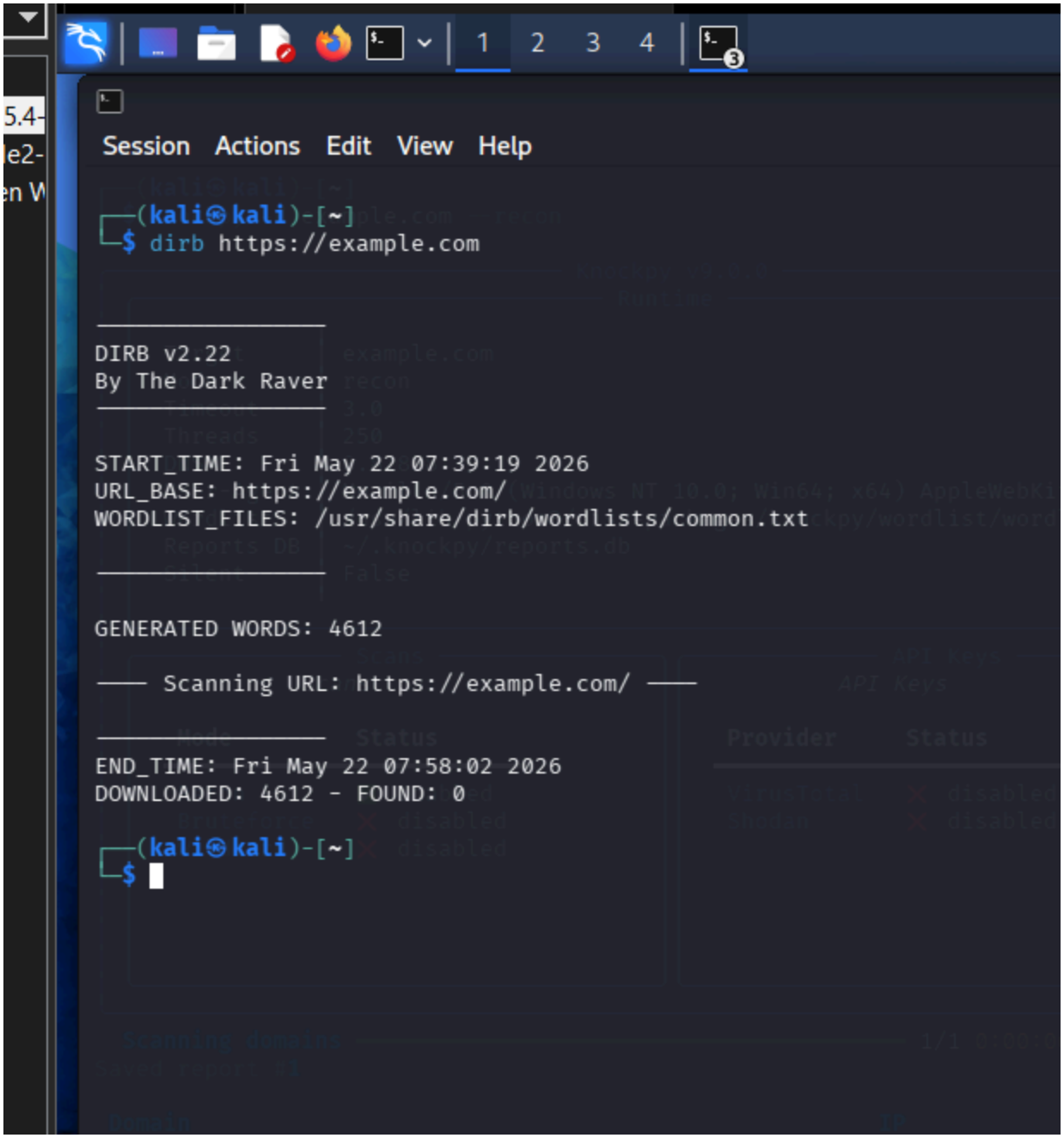
- sublist3r
- dirb
- KnockPy

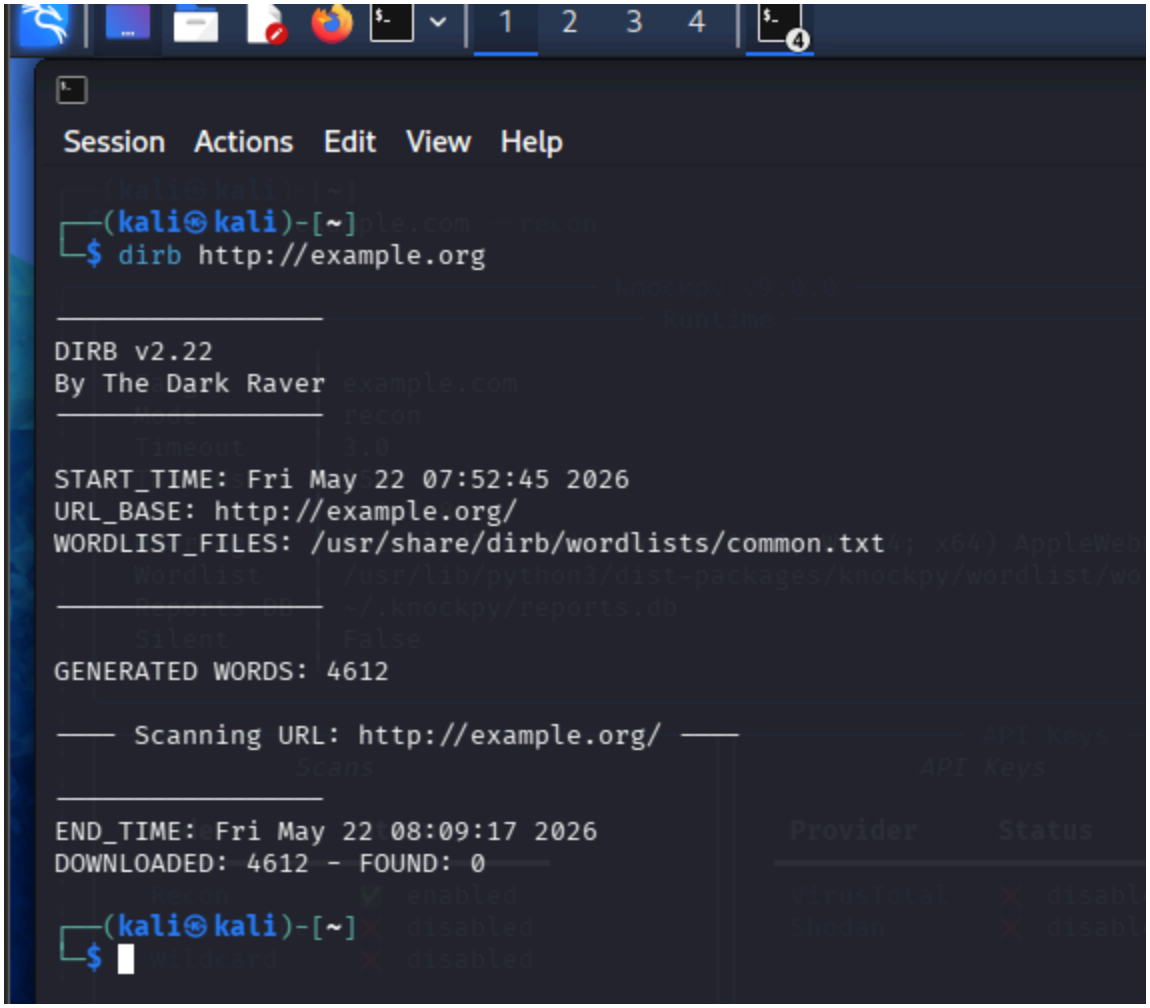
Exercise 1:
Ran the `sublist3r` command for the following domains:
- github.com
- google.com

Findings:
1. Subdomains for github.com:
   135 unique subdomains were discovered.

2. Subdomains for google.com:
   180 unique subdomains were discovered.

Exercise 2:
Perform a directory discovery scan on the following targets:
Commands used:
- dirb http://example.com`
- dirb http://example.org`


1 2 3 4
Session Actions Edit View Help
(kali㉿kali)-[~]
$ dirb https://example.com
DIRB v2.22
By The Dark Raver
START_TIME: Fri May 22 07:39:19 2026
URL_BASE: https://example.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
GENERATED WORDS: 4612
Scanning URL: https://example.com/
END_TIME: Fri May 22 07:58:02 2026
DOWNLOADED: 4612 - FOUND: 0
(kali㉿kali)-[~]
$



Findings:

1. Directories for example.com:
 - dirb tested 4612 possible directories/files but found nothing on https://example.com

2. Directories for example.org
- dirb tested 4612 possible directories/files but found nothing on https://example.com

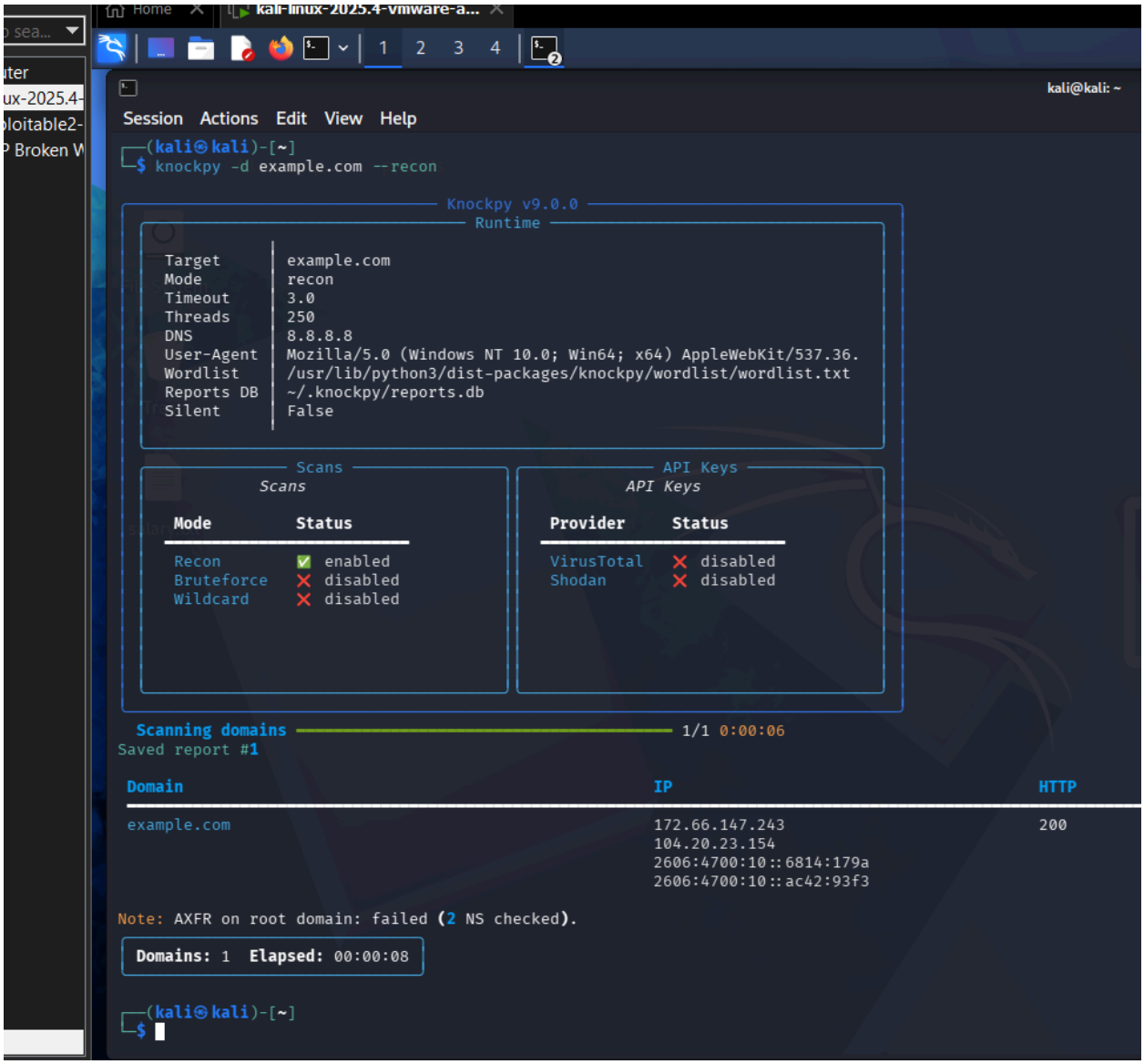
Exercise 3

Use `KnockPy` to enumerate subdomains for the following domain:

Target Domain: example.com

Commands used:

Knockpy -d example.com --recon



Findings

Discovered Subdomains and Information:

KnockPy checked subdomains for `example.com`

- It found no subdomains
- It tried DNS zone transfer (AXFR) but failed

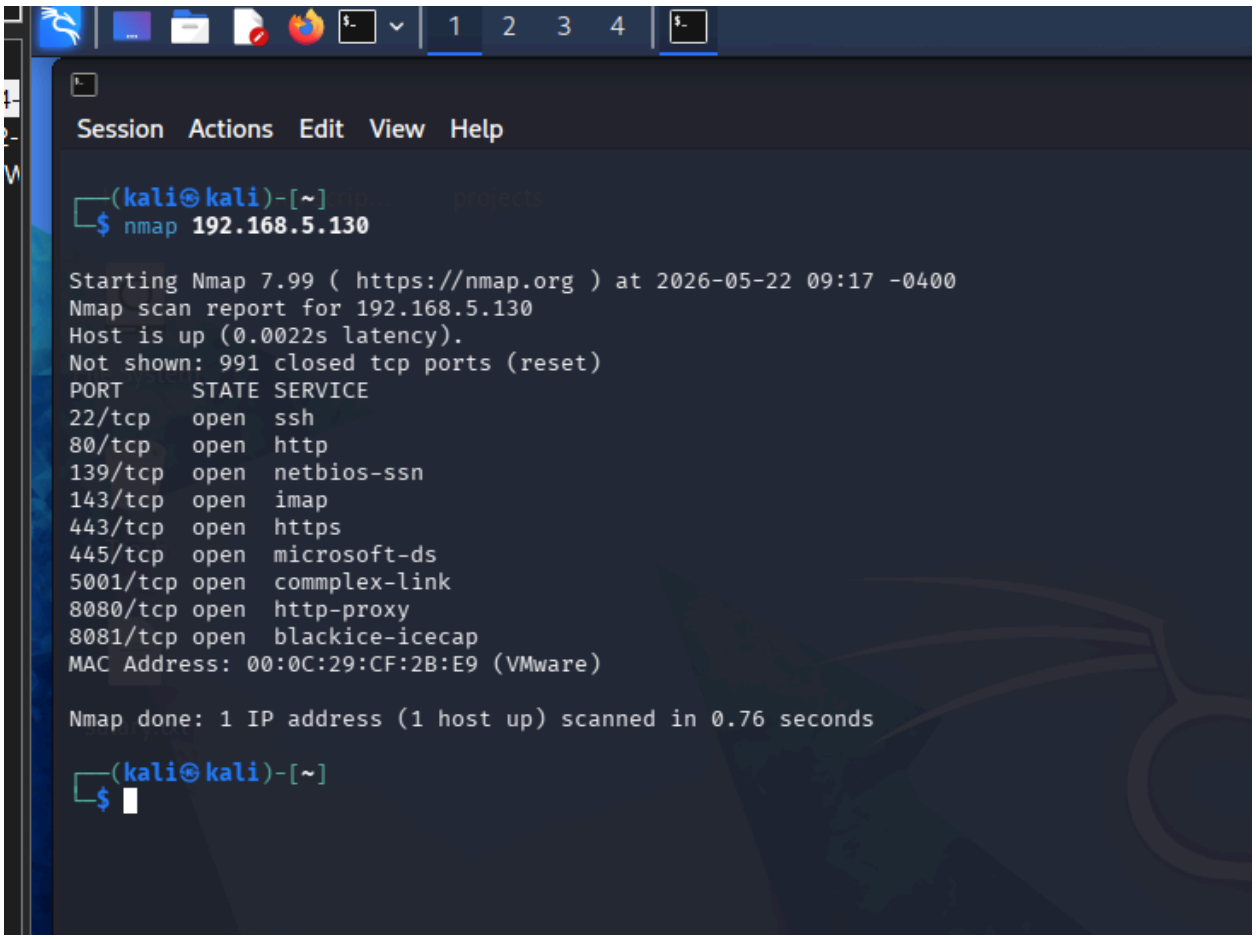
Lab 4: Basic Port Scanning

Tools Used

- Kali Linux
- nmap
- Nikto

Exercise 1:

Perform a basic port scan on your OWASP VM IP address and record
Command Used: nmap 192.168.5.130



findings:

- Open Ports: 8080,22,80,139,143,443,445,5001 and port 8081

Exercise 2:

Perform an aggressive scan on your OWASP VM IP address
Command used:nmap -sV -O 192.168.5.130



findings:

Service Versions:

- OpenSSH 5.3p1 Debian 3ubuntu4
- Apache httpd 2.2.14
- Samba smbd 3.x – 4.x
- Courier IMAP (2008 release)
- Apache httpd 2.2.14 (SSL)
- Samba smbd 3.x – 4.x
- Java Object Serialization (port 5001)
- Apache Tomcat/Coyote JSP engine 1.1

- Jetty 6.1.25

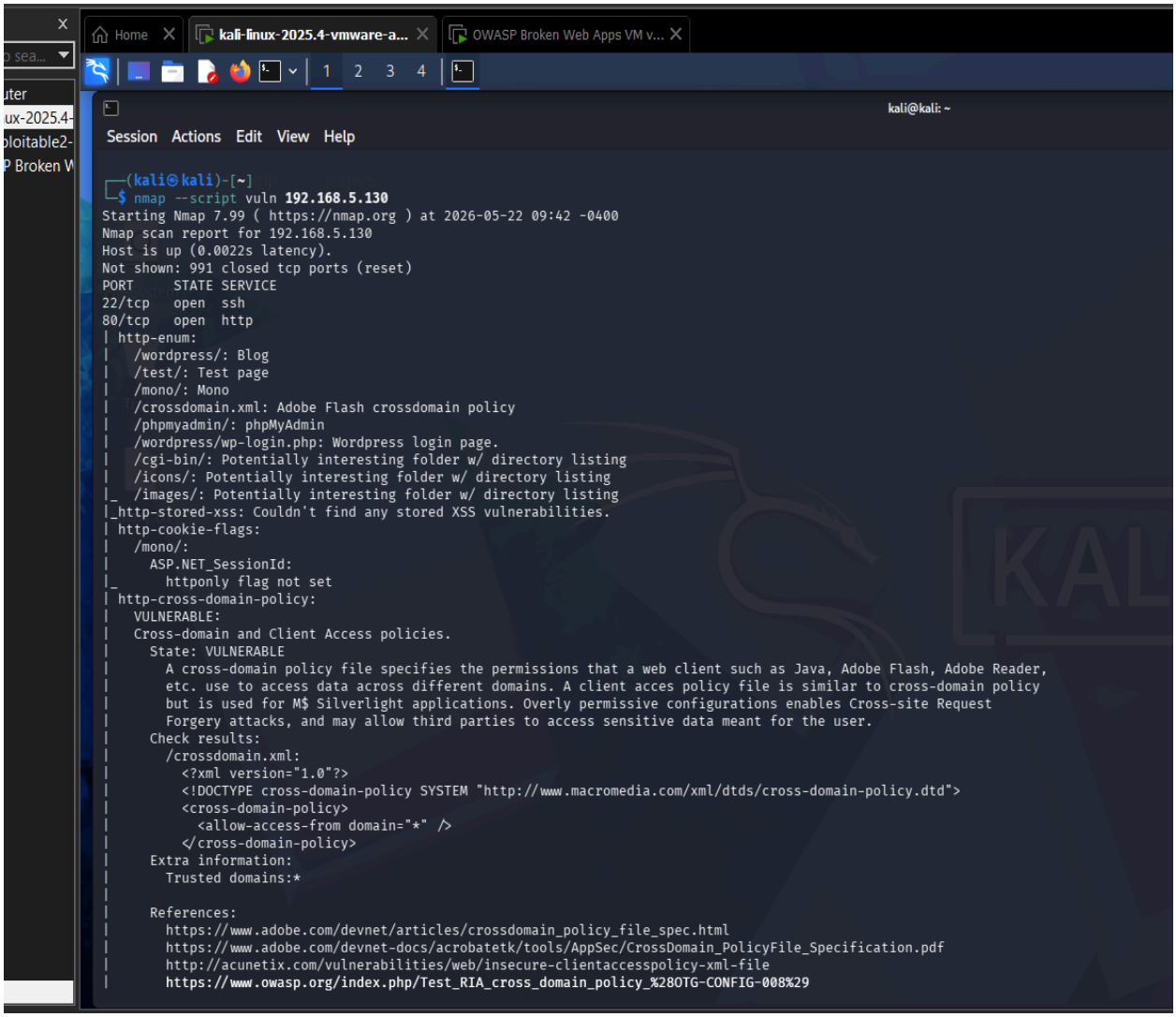
Operating System:

- Linux 2.6.17 – 2.6.36 (Ubuntu Linux)
- VMware virtual machine

Exercise 3:

Conducted a vulnerability scan on OWASP VM IP address

Commands Used:nmap --script vuln 192.168.5.130



findings:

Vulnerabilities:

- Cross-domain and Client Access policy misconfiguration (/crossdomain.xml)
- Apache byterange filter DoS (CVE-2011-3192)
- HTTP TRACE method enabled
- Internal IP disclosure (127.0.1.1)
- CSRF vulnerabilities (multiple forms on WordPress, Railsgoat, phpBB2, etc.)
- SSL/TLS CCS Injection (CVE-2014-0224)
- Weak Diffie-Hellman group (1024-bit MODP)

- SSL POODLE vulnerability (CVE-2014-3566)
- Missing HTTPOnly cookie flag (ASP.NET_SessionId)
- Missing Secure cookie flag (HTTPS session cookies)
- Directory listing enabled (/cgi-bin/, /icons/, /images/)
- phpMyAdmin exposed (/phpmyadmin/)
- WordPress login exposed (/wordpress/wp-login.php)
- Apache Tomcat admin endpoints exposed (/manager/html, /upload)
- Potential SQL injection script failure (http-sql-injection script error reported)

Exercise 4:

Performed a vulnerability scan on OWASP VM
Commands Used:

1. nikto -h 192.168.5.130



findings:

Vulnerabilities Found:

- ETags inode leakage (CVE-2003-1418)
- Directory indexing enabled (/icons/, /cgi-bin/, /test/, /images/)

- Outdated Apache 2.2.14
- Outdated PHP 5.3.2 (EOL)
- Outdated OpenSSL 0.9.8k (EOL)
- Outdated Python 2.6.5 (EOL)
- Outdated Perl 5.10.1 (EOL)
- Outdated mod_ssl 2.2.14 (possible RCE risk)
- Outdated mod_mono 2.4.3
- Outdated Phusion Passenger 4.0.38
- Outdated mod_perl 2.0.4
- Outdated mod_python 3.3.1
- Internal IP disclosure (127.0.1.1 via Location header)
- Missing security headers:
  - HSTS
  - CSP
  - X-Content-Type-Options
  - Referrer-Policy
  - Permissions-Policy
- mod_negotiation MultiViews enabled (file brute-force risk)
- HTTP TRACE method enabled (XST risk)
- OPTIONS method enabled (GET, POST, TRACE, OPTIONS)
- mod_ssl buffer overflow risk (legacy versions)
- phpMyAdmin exposed (/phpmyadmin/)
- WordPress login exposed (/wordpress/wp-login/)
- phpBB cookies missing HttpOnly flag
- Apache default file exposed (/icons/README)
- Potential sensitive test directory exposed (/test/)